policy evaluation, and how context can be standardized across systems. This foundation will clarify how policies connect to the real-world actions they oversee.

11.4 Summary

- ACME secures APIs on two fronts: Cedar policies safeguard internal microservices at gateways, meshes, and proxies, while OAuth tokens—combined with Cedar—allow safe external delegation to customer applications.
- API authorization needs to manage both internal service-to-service calls and external third-party integrations.
- ACME enforces internal policies using gateway, service mesh, and per-service proxy patterns, with Cedar serving as the decision engine.
- OAuth enables delegated access without sharing passwords, with scopes specifying which APIs a token bearer can access.
- The Authorization Code Grant (Kate’s BI Explorer) and Client Credentials Grant (CustCo’s Task App) demonstrate the two most important methods for obtaining tokens.
- Regardless of grant type, tokens are validated at the gateway and then converted into PARC requests for Cedar, which enforces detailed access control.